

Risk List

Список рисков

1. Introduction (Введение)

Документ содержит перечень рисков проекта разработки SCMS, их оценку и стратегии смягчения.

1.1 Purpose (Назначение)

Идентифицировать, оценить и спланировать меры по управлению рисками проекта SCMS. Обеспечить готовность команды к нештатным ситуациям.

1.2 Scope (Область применения)

Риски, связанные с разработкой, внедрением и эксплуатацией SCMS. Включены технологические, процессные, политические, юридические и операционные риски.

1.3 Definitions, Acronyms, and Abbreviations (Определения и аббревиатуры)

Термин / Аббревиатура	Определение	Используется в документах
SCMS	Sleeving Clinic Management System — разрабатываемая система.	Все документы проекта
Stack / Кортикальный стек	Устройство хранения сознания, имплантируемое в затылок.	Vision, SRS, Glossary
Sleeve	Клонированное или подобранное тело для переноса сознания.	Vision, SRS, Glossary
Meth	Сверхбогатый клиент клиники, владелец множества стеков.	Vision, SRS, Glossary
Needlecast	Процесс передачи сознания из стека в нейроны нового тела.	Vision, SRS, Glossary
DHF	Digital Human Freight — цифровые данные сознания.	Vision, SRS, Glossary
Stack Shock	Психосоматический шок после переноса сознания.	Vision, SRS, Glossary
FR	Functional Requirement — функциональное требование.	SRS, SAD, TestPlan

RBAC	Role-Based Access Control — ролевая модель доступа.	SRS, SAD
2FA	Two-Factor Authentication — двухфакторная аутентификация.	SRS, Glossary
MTTR	Mean Time To Recovery — среднее время восстановления системы.	SRS, SDP, TestPlan
Audit Log	Неизменяемый журнал всех операций в системе.	SRS, SAD, Glossary
NDA	Non-Disclosure Agreement — соглашение о неразглашении.	Glossary

Детальные определения всех терминов приведены в документе «Glossary (Глоссарий)» проекта SCMS.

1.4 References (Ссылки)

- SRS (Спецификация требований) проекта SCMS, версия 1.0.
- SDP (План разработки) проекта SCMS, версия 1.0.

1.5 Overview (Обзор документа)

Раздел 1.6 содержит шкалу оценки рисков. Раздел 2 содержит детальное описание каждого риска: вероятность и серьёзность, описание, влияние, признаки, стратегия смягчения и план действий при наступлении.

1.6 Risk Scale (Шкала оценки рисков)

Вероятность	Описание
Высокая	Событие произойдёт с вероятностью >70%
Средняя	Событие может произойти с вероятностью 30–70%
Низкая	Событие маловероятно (менее 30%)

Серьёзность	Описание
Критическая	Остановка проекта, потеря лицензии, необратимые последствия
Высокая	Серьёзные задержки, крупные финансовые потери, потеря данных
Средняя	Заметные проблемы, влияющие на сроки или бюджет, но решаемые
Низкая	Незначительные неудобства, не влияющие на сроки проекта

2. Risks (Риски)

2.1 R1: Технический долг и снижение качества кода

2.1.1 Risk Magnitude or Ranking (Вероятность появления и серьезность)

Вероятность: Высокая. Серьезность: Средняя. Тип риска: Разработка. Порог: покрытие тестами < 30%.

В условиях жёсткого дедлайна (4 месяца) и малой команды (2 разработчика) возникает соблазн сокращать рефакторинг, пропускать code review и писать «быстрые» решения. Технический долг накапливается, что замедляет разработку в поздних итерациях и увеличивает количество дефектов.

2.1.3 Impacts (Влияние)

- Замедление добавления новых функций из-за сложности поддержки кода.
- Рост количества дефектов в уже работающих модулях.
- Невозможность передать код другому разработчику без длительного погружения.

2.1.4 Indicators (Признаки проявления)

- Увеличение времени на реализацию типовой задачи от итерации к итерации.
- Частые баги при добавлении новых функций в существующие модули.
- Отсутствие unit-тестов, низкое покрытие кода.

2.1.5 Mitigation Strategy (Стратегия смягчения)

- Code review обязателен для всех изменений — оба разработчика проверяют код друг друга.
- Выделение времени на рефакторинг в каждой итерации (до 20% спринта).
- Использование статического анализа кода (SonarQube, Checkstyle) в CI/CD.

2.1.6 Contingency Plan (Стратегия наступления)

- Приоритизация: рефакторинг критических модулей (аудит-лог, данные клиентов) в первую очередь.
- Снижение планки качества для некритичных функций ради соблюдения сроков.

2.2 R2: Утечка конфиденциальных данных клиентов

2.2.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьезность: Критическая. Тип риска: Безопасность. Порог: обнаружение несанкционированного доступа.

2.2.2 Description (Описание)

Несанкционированный доступ к данным клиентов (личная информация, история операций, медицинские записи) через уязвимости в системе, перехват трафика или инсайдерские действия. Для клиник уровня Meth компрометация данных означает потерю репутации и судебные иски.

2.2.3 Impacts (Влияние)

- Юридические иски от клиентов, компенсации до 50 млн кредитов.
- Отзыв лицензии клиники регулятором (Протекторат Бей-Сити).
- Потеря доверия и закрытие бизнеса.

2.2.4 Indicators (Признаки проявления)

- Необычная активность в audit-log (множественные неудачные попытки входа).
- Запросы к данным с IP-адресов за пределами сети клиники.

- Срабатывание IDS/IPS системы безопасности.

2.2.5 Mitigation Strategy (Стратегия смягчения)

- Шифрование всех чувствительных данных (TLS для передачи, AES для хранения).
- Аутентификация 2FA для всех учётных записей.
- RBAC: строгое разграничение доступа по ролям сотрудников.
- Аудит-лог с однократной записью (append-only), доступный только администратору.

2.2.6 Contingency Plan (Стратегия наступления)

- Немедленная блокировка скомпрометированной учётной записи.
- Запуск расследования: анализ audit-log, идентификация источника утечки.
- Уведомление затронутых клиентов и регулятора.
- Смена всех ключей шифрования и паролей.

2.3 R3: Срыв сроков разработки

2.3.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Высокая. Серьёзность: Средняя. Тип риска: Разработка (процессный). Порог: отставание от графика > 2 недель.

2.3.2 Description (Описание)

Невыполнение плана разработки в установленные сроки (4 месяца) из-за недооценки сложности, изменения требований, технических проблем или низкой производительности. Учитывая малый размер команды, любая задержка критична.

2.3.3 Impacts (Влияние)

- Невозможность завершить все запланированные функции к дедлайну.
- Сжатие фазы тестирования (риск пропуска критических дефектов).
- Недовольство заказчика, потеря репутации команды.

2.3.4 Indicators (Признаки проявления)

- Отставание от графика >10% в итерации.
- Незавершённые задачи переходят в следующий спринт.
- Частые переоценки трудозатрат на задачи.

2.3.5 Mitigation Strategy (Стратегия смягчения)

- Приоритизация требований: критичные функции реализуются в первую очередь.
- Еженедельный review прогресса с заказчиком.
- Буфер времени: 2 недели на непредвиденные задержки.

2.3.6 Contingency Plan (Стратегия наступления)

- Пересмотр плана: перемещение некритичных функций в следующий релиз.
- Фокус на рабочем MVP с базовым функционалом вместо полного набора функций.

2.4 R4: Недостаточное тестирование и регрессионные ошибки

2.4.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Высокая. Серьёзность: Высокая. Тип риска: Разработка (процессный). Порог: покрытие тестами < 20%.

В команде нет выделенного QA-инженера — тестирование выполняют те же 2 разработчика. При сжатии сроков тестирование страдает в первую очередь: unit-тесты не пишутся, регрессионное тестирование пропускается, критические дефекты уходят в продакшен.

2.4.3 Impacts (Влияние)

- Критические дефекты в модулях аудит-лога и данных клиентов (юридические риски).
- Потеря данных или некорректная генерация сертификатов.
- Нестабильная работа системы в демонстрациях заказчику.

2.4.4 Indicators (Признаки проявления)

- Падение покрытия кода тестами ниже 30%.
- Пропуск этапа тестирования в итерации из-за нехватки времени.
- Повторное возникновение ранее исправленных багов.

2.4.5 Mitigation Strategy (Стратегия смягчения)

- Автоматизированное тестирование: unit + smoke-тесты в CI/CD на каждый коммит.
- Определение критического функционала (core-модули), обязательного к тестированию.
- Чек-лист регрессионного тестирования перед каждым релизом.

2.4.6 Contingency Plan (Стратегия наступления)

- Приоритетное исправление критических дефектов перед добавлением новых функций.
- Временное привлечение внешнего тестировщика (студент-стажёр).

2.5 R5: Технические проблемы интеграции и развёртывания

2.5.1 Risk Magnitude or Ranking (Вероятность и серьёзность)

Вероятность: Средняя. Серьёзность: Средняя. Тип риска: Разработка (технологический).
Порог: 3+ неудачных сборки подряд.

2.5.2 Description (Описание)

Сложности при интеграции backend (Spring Boot), frontend (React) и базы данных (PostgreSQL), а также при развёртывании на сервере helios.cs.ifmo.ru (FreeBSD). Отличия окружения разработки от продакшена могут вызвать неожиданные ошибки.

2.5.3 Impacts (Влияние)

- Задержка развёртывания, невозможность показать работающий продукт к демо.
- Потеря времени на отладку инфраструктурных проблем.
- Нестабильная работа системы на целевом сервере.

2.5.4 Indicators (Признаки проявления)

- Различия в поведении приложения на локальной машине и на сервере.
- Ошибки при сборке Docker-образов.
- Проблемы с сетевыми портами и правами доступа на helios.

2.5.5 Mitigation Strategy (Стратегия смягчения)

- Контейнеризация через Docker Compose — единое окружение для разработки и сервера.
- CI/CD: автоматическая сборка и тестирование при каждом push.
- Раннее развёртывание прототипа на сервере (фаза Elaboration) для выявления проблем.

2.5.6 Contingency Plan (Стратегия наступления)

- Откат к предыдущей стабильной версии при критических ошибках.
- Привлечение DevOps-специалиста (внешний консультант) для настройки сервера.
- Временное использование альтернативного окружения (например, облачный сервер).

2.6 R6: Проблемы производительности и масштабирования

2.6.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьезность: Средняя. Тип риска: Разработка (технологический).

Порог: время отклика API > 1 сек при 10+ запросах.

2.6.2 Description (Описание)

Система SCMS должна поддерживать до 50 одновременных пользователей с откликом ≤ 0.5 сек для персонала и ≤ 100 мс для мониторинга needlecast. Некорректная архитектура БД, отсутствие кэширования или неоптимальные запросы могут привести к падению производительности в пиковые моменты.

2.6.3 Impacts (Влияние)

- Задержки отображения данных мониторинга needlecast (превышение 100 мс).
- Невозможность одновременной работы нескольких сотрудников с каталогом sleeves.
- Снижение удовлетворённости заказчика при демонстрации системы.

2.6.4 Indicators (Признаки проявления)

- Время отклика API превышает 500 мс при 10+ одновременных запросах.
- Долгая загрузка страниц каталога sleeves (более 3 сек).
- Рост потребления памяти и CPU на сервере без увеличения нагрузки.

2.6.5 Mitigation Strategy (Стратегия смягчения)

- Кэширование часто запрашиваемых данных (каталог sleeves) через Redis.
- Оптимизация запросов к БД (индексы, пагинация, N+1 query detection).
- Нагрузочное тестирование в CI/CD после каждого крупного изменения.

2.6.6 Contingency Plan (Стратегия наступления)

- Вертикальное масштабирование сервера (увеличение ресурсов helios).
- Добавление реплик чтения БД для разгрузки основной базы.
- Временное отключение некритичных функций (аналитика, отчёты) под нагрузкой.

2.7 R7: Политические санкции и изменение регулирования

2.7.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьезность: Критическая. Тип риска: Политический. Порог: официальное уведомление от Протектората.

2.7.2 Description (Описание)

Протекторат ООН или сенаторы Бей-Сити могут ввести новые ограничения на манипуляции с DHF (Digital Human Freight), включая требования обязательного аудита, лицензирования каждого needlecast или полный запрет на определённые виды переноса. Клиника работает в серой зоне закона — любое ужесточение регулирования может потребовать кардинального изменения функционала SCMS или приостановки операций.

2.7.3 Impacts (Влияние)

- Необходимость срочной доработки системы под новые требования регуляторов.
- Приостановка операций клиники на время приведения системы в соответствие.
- Потеря лицензии клиники, невозможность проведения needlecast.
- Штрафные санкции от Протектората до 10 млн кредитов.

2.7.4 Indicators (Признаки проявления)

- Публичные заявления сенаторов Бей-Сити о необходимости регулирования DHF.
- Внеплановые проверки Протекторатом других клиник sleeving в городе.
- Утечки в СМИ о несчастных случаях при переносе сознания в других клиниках.

2.7.5 Mitigation Strategy (Стратегия смягчения)

- Модульная архитектура SCMS, позволяющая быстро добавлять новые поля отчётности и проверки.
- Встроенный аудит-лог по всем операциям для предоставления регуляторам.
- Разработка системы генерации отчётов для Протектората (гибкие шаблоны).

2.7.6 Contingency Plan (Стратегия наступления)

- Юридический аудит системы внешними консультантами по требованию Протектората.
- Быстрая имплементация новых требований через выделенную итерацию разработки.
- Привлечение Envoy Corps как консультантов для подтверждения безопасности процедур.

2.8 R8: Давление религиозных и общественных организаций

2.8.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Высокая. Серьёзность: Средняя. Тип риска: Политический. Порог: появление пикетов или публикации в топ-СМИ.

2.8.2 Description (Описание)

Католическая церковь осуждает использование кортикальных стеков и перенос сознания как вмешательство в божественную природу человека. Церковь регулярно организует пикеты у клиники, публикует статьи в СМИ Бей-Сити и лоббирует сенаторов для введения запретов. Негативное освещение в прессе может отпугнуть клиентов Meths, требующих абсолютной приватности.

2.8.3 Impacts (Влияние)

- Отток клиентов Meths, не желающих ассоциироваться со скандальной клиникой.
- Давление на владельца здания со стороны арендодателей (угроза расторжения договора аренды).
- Дополнительные требования к системе по сокрытию информации о клиентах.
- Усиление охраны и проверок безопасности (рост операционных расходов).

2.8.4 Indicators (Признаки проявления)

- Появление пикетов у здания клиники.
- Критические статьи в СМИ Бей-Сити о процедурах sleeving.
- Запросы от журналистов, попытки проникновения в систему.

2.8.5 Mitigation Strategy (Стратегия смягчения)

- Усиленная система безопасности и анонимизации данных клиентов в SCMS.
- Модуль управления репутацией: мониторинг упоминаний в СМИ, генерация ответов.
- Строгое разграничение доступа: даже администратор не видит полные данные Meth без дополнительной авторизации.

2.8.6 Contingency Plan (Стратегия наступления)

- Найм PR-агентства для управления репутацией (внешний бюджет).
- Временное приостановление приёма новых клиентов до снижения медийного давления.
- Перенаправление трафика через анонимные прокси и VPN для сокрытия IP клиники.

2.9 R9: Юридические претензии от клиентов и семей Meth

2.9.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьёзность: Высокая. Тип риска: Юридический. Порог: получение официальной претензии от адвоката Meth.

2.9.2 Description (Описание)

Meths и их семьи могут подать судебные иски против клиники в случаях: несовместимость тела со стеком (stack shock), фрагментация личности после переноса, изменение деловых качеств Meth (что влияет на завещания и контракты), утечка данных о состоянии здоровья. Каждый иск может стоить клинике до 50 млн кредитов компенсации.

2.9.3 Impacts (Влияние)

- Финансовые потери на компенсации и судебные издержки.
- Требования к SCMS по предоставлению полных audit-log по каждому кейсу.
- Усложнение процесса сертификации (дополнительные проверки Psychosurgeon).
- Заморозка счетов клиники по решению суда, блокировка операций.

2.9.4 Indicators (Признаки проявления)

- Жалобы Meths или их представителей на качество переноса.
- Запросы от адвокатов семей Meth на предоставление данных.
- Претензии к сертификатам совместимости, выданным Psychosurgeon.

2.9.5 Mitigation Strategy (Стратегия смягчения)

- Детальный аудит-лог каждой операции с цифровой подписью сотрудника.
- Электронные сертификаты совместимости с криптографической подписью Psychosurgeon.
- Хранение всех медицинских записей в неизменяемом виде (append-only storage).
- Встроенные чеклисты и протоколы для Psychosurgeon (минимизация человеческой ошибки).

2.9.6 Contingency Plan (Стратегия наступления)

- Автоматическая генерация полного отчёта по кейсу для юридического отдела.
- Блокировка доступа к данным кейса для всех, кроме юридической команды.
- Внешний аудит системы независимым экспертом для подтверждения корректности.

2.10 R10: Зависимость от внешних поставщиков

2.10.1 Risk Magnitude or Ranking (Вероятность и серьезность)

Вероятность: Средняя. Серьёзность: Высокая. Тип риска: Операционный. Порог: отказ API поставщика > 4 часов.

2.10.2 Description (Описание)

SCMS зависит от внешних поставщиков: генетические архивы (данные о клонированных телах), охранные корпорации (системы безопасности и квантовое шифрование для хранилищ DHF), облачные сервисы (мониторинг). Срыв поставок, повышение цен (до 300% для клиник уровня Meth), банкротство поставщика могут парализовать работу клиники.

2.10.3 Impacts (Влияние)

- Невозможность получения данных о доступных sleeves (остановка подбора тела).
- Потеря защищённого канала для передачи DHF (невозможность needlecass).
- Рост операционных расходов при переходе на альтернативных поставщиков.
- Необходимость экстренной интеграции с новыми API поставщиков в SCMS.

2.10.4 Indicators (Признаки проявления)

- Уведомления от поставщиков об изменении условий контрактов или цен.
- Сбои в интеграции с API генетических архивов.
- Отказы систем безопасности (невозможность верификации личности сотрудников).

2.10.5 Mitigation Strategy (Стратегия смягчения)

- Поддержка интеграции с минимум двумя поставщиками каждого типа (архивы, охрана).
- Абстрактный слой интеграции в архитектуре SCMS (легкая смена провайдера).
- Регулярное резервное копирование данных генетических архивов локально.
- Локальное кэширование критичных данных (каталог sleeves) для автономной работы.

2.10.6 Contingency Plan (Стратегия наступления)

- Экстренный переход на резервного поставщика (переключение API-ключа в SCMS).
- Использование локального хранилища данных до восстановления основного поставщика.
- Ручной ввод данных при недоступности API (режим офлайн с последующей синхронизацией).